PHASE 2 · DATA SOURCING · CORRECTED 6 SEPTEMBER 2026

# Phase 2 datasets

Which second exploitation catalogue to use, and the four reasons the obvious choice does not work as shipped. Supersedes the 5 September version, which contained an error that would have produced a silent failure in the estimator.

Companion to **LEV-calibration-Phase1.pdf** · machine-readable version in **DATASETS.md** · prompt in **RESEARCH-PROMPT.md**

---

### VulnCheck KEV is a superset of CISA KEV, not an independent list.

Their documentation: "encompasses all vulnerabilities listed in the CISA KEV catalog, plus approximately 80% more." Lincoln–Petersen on the pair as downloaded gives `m = |L1|` by construction and collapses to `|L2|`. The arithmetic runs and returns a plausible number — the worst kind of bug. **It is still the right source**, but only after the filter in §1.

CORRECTION 1

## Constructing an independent list from VulnCheck

The schema exposes provenance per report, so a CISA-free list `L2'` can be built rather than assumed. `cisa_date_added` is the marker of contamination, not a convenient join.

| | |
|---|---|
| 1 | Drop `cisa_date_added` entirely. |
| 2 | Filter `vulncheck_reported_exploitation[]` to reports whose URL host is not `cisa.gov` / `www.cisa.gov`. |
| 3 | Keep a CVE only if a report survives step 2, **or** `reported_exploited_by_vulncheck_canaries == true`. |
| 4 | First-observation date = `min(date_added)` over surviving reports. |

> The canaries flag is VulnCheck's own honeypot telemetry, structurally independent of CISA. **That subset alone is a defensible L2** if the URL filter draws reviewer objections. Document the filter in the paper — it is a methodological contribution in its own right, and no prior work does it.

CORRECTION 2

## Four sources measure the wrong quantity

Exploit-DB, Metasploit, Nuclei and AttackerKB record exploit *availability*, or analyst assessment of it — not exploitation in the wild. A CVE with a Metasploit module and no observed attack traffic is a capture in that list and a non-capture in CISA KEV, so including it estimates "CVEs with public tooling": a different and much larger population.

> **Exclude all four as capture lists. Keep them as covariates.** A CVE with a public PoC is more likely to be captured by *every* list, which is exactly the dependence the model has to absorb. This is an estimand objection, not an access one.

CORRECTION 3

## Circularity with EPSS — and it reaches Phase 1

EPSS's exploitation labels come from Fortinet, AlienVault, Shadowserver and GreyNoise (Jacobs et al., arXiv:2302.14172). LEV is computed *from* EPSS, so validating LEV against GreyNoise or Shadowserver is partly circular.

> **Worse, and this hits work already done.** CISA KEV is an input *feature* to EPSS v3 — "Public vulnerability lists (3 features): CISA KEV, Google Project Zero, Trend Micro ZDI." Phase 1 therefore compared a predictor that has the outcome baked in to it. Measured in `analysis/leakage.py`:

| COHORT | N | IN KEV | MEAN LEV | OBSERVED | OVER-CONFIDENCE |
|---|---|---|---|---|---|
| All CVEs, as reported in Phase 1 | 100,905 | 471 | 0.0555 | 0.00467 | 11.9× |
| Leak-free (not on KEV when the model was trained) | 100,598 | 164 | 0.0533 | 0.00163 | **32.7×** |

The direction is the good one for the central claim: **over-confidence nearly triples once the leak is removed**, so the published 17.2× and 12.6× figures are *conservative*. A model partly told the answer still over-predicts by an order of magnitude.

> It cuts the other way on discrimination. Leak-free, the observed/predicted ratio spans only 0.019–0.047 across the ten buckets, against 0.010–0.131 with the leak included. The top bucket's departure from the plateau — 3.29× raw, 2.31× normalized — is **largely circularity**. Soften the top-bucket claims; keep the over-confidence claim.

CORRECTION 4

## Independence is violated everywhere — model it, do not assume it

Every catalogue in this space reads the same vendor advisories and the same security blogs. Naive two-source Lincoln–Petersen assumes independent capture and will be rejected in review.

| | |
|---|---|
| **`Log-linear MSE`** | Interaction terms across ≥ 3 lists, so positive list dependence is a fitted parameter rather than an assumption. |
| **`Stratification`** | By vendor tier and disclosure year. Phase 1 already measured capture probability varying 14× by vendor; pooling gives the classic downward-biased estimate. |
| **`Chao lower bound`** | Robustness check — consistent under unmodelled heterogeneity, and gives a defensible floor. |

A third list is what makes the log-linear approach possible at all.

RANKING

## Which sources, in order

| # | SOURCE | VERDICT |
|---|---|---|
| 1 | **VulnCheck KEV Community** | **Best.** The only source with per-report provenance and dates, so independence can be *constructed* rather than asserted. Free, one API key, single bulk download. |
| 2 | **CIRCL Vulnerability-Lookup** | **Best third list.** No auth at all. Carries Shadowserver honeypot data via the ShadowSight feeder with `type=exploited` — real sensor telemetry without a Shadowserver contract. Coverage depth unverified. |
| 3 | **ENISA EUVD** | Good third or fourth list, no auth, EU-sourced. `/api/kev/dump` is explicitly a CISA+EU consolidation — use `/api/search?exploited=true` and treat the KEV dump as contaminated. |
| 4 | **GreyNoise** | Strong data and genuinely independent of CISA, but EPSS-circular per correction 3, and access is reviewed rather than instant. Apply now regardless — it is the long pole. |
| 5 | **Project Zero 0day ITW** | Small N, browser and mobile skewed, and itself an EPSS feature. Not a second list; a high-precision stratum at best. |
| 6 | **Shadowserver (direct)** | Effectively unobtainable — reports are scoped to IP space you can prove you own. Route via CIRCL instead. |
| – | **Exploit-DB, Metasploit Nuclei, AttackerKB** | Excluded on **estimand** grounds (correction 2), not access grounds. |

> **If only one: VulnCheck KEV Community.** It is the only candidate where the schema itself lets you demonstrate independence to a reviewer, rather than argue for it. Everything else requires an assumption you cannot support with a field name.

ACCESS

## Where to get them

NO AUTH Fetch today

| | |
|---|---|
| **CISA KEV** | `cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json` |
| **CISA KEV history** | `github.com/cisagov/kev-data` · `github.com/hrbrmstr/cisa-known-exploited-vulns` (MIT, daily snapshots) |
| **EPSS history** | `github.com/empiricalsec/epss_scores` — ~2.5 GB, no licence declared |
| **ENISA EUVD** | `euvdservices.enisa.europa.eu/api/search?exploited=true` · id map at `/api/dump/cve-euvd-mapping` |
| **CIRCL sightings** | `vulnerability.circl.lu/api/sighting/?vuln_id=CVE-XXXX-NNNNN` |

FREE KEY Minutes to obtain

| | |
|---|---|
| **VulnCheck KEV** | `api.vulncheck.com/v3/backup/vulncheck-kev` with `Authorization: Bearer <token>`. Take the bulk ZIP, not per-CVE calls. 1,000 req/min. |
| **GreyNoise Community** | `api.greynoise.io/v3/community/{ip}` — signup **rejects gmail**, use the institutional address |

REVIEWED Start first — human turnaround

| | |
|---|---|
| **GreyNoise Research** | `info.greynoise.io/community/research-program-request` — full Enterprise API, free for research. **The long pole; apply now.** |
| **Shadowserver** | `transform.shadowserver.org/api2/` — normally granted only for IP space you can prove you own. Treat as unavailable. |

PRIOR WORK

## Nothing found on either question

| | |
|---|---|
| **Capture–recapture on catalogue completeness** | **None found.** Nearest adjacent work is descriptive overlap comparison, not estimation. This is the strongest novelty claim available. |
| **LEV evaluation since May 2025** | **None found peer-reviewed.** Cite and differentiate: a reference implementation (RiskBasedPrioritization/LEV); a theoretical objection that CSWP 41 misreads EPSS as past rather than next-30-days exploitation; Parla (arXiv:2411.02618); and arXiv:2506.01220, which reports 48 exploited CVEs caught by neither KEV nor EPSS individually — the closest existing result. NIST itself states it is seeking partners with real-world datasets to evaluate LEV; cite as motivation. |

> **This was a targeted search, not a systematic one.** Before submission, sweep arXiv cs.CR, WEIS, eCrime, ACM CCS and IEEE S&P from June 2025 onward for LEV specifically. One missed prior evaluation costs the novelty claim.

> **Licensing is still unresolved.** VulnCheck's Attribution Notice covers use “in your own production, solution, or service” and is *silent* on peer-reviewed publication of derived data and on archiving raw data. Email `community@vulncheck.com` and get it in writing. The EPSS history repository declares no licence at all.

ACTIONS

## Do this week

1. Register VulnCheck Community, pull `/v3/backup/vulncheck-kev`, and build `L2'` per the §1 filter. That unblocks the whole study.
2. Apply to the GreyNoise Research Community. Reviewed by a human, so it is the long pole.
3. Email `community@vulncheck.com` on publication and archival rights, in writing.
4. Run the systematic prior-art sweep before committing to the novelty claim.

---

Corrected 6 September 2026. Sources: docs.vulncheck.com/community/vulncheck-kev · arxiv.org/abs/2302.14172 (EPSS v3 features and labels) · vulnerability.circl.lu · euvd.enisa.europa.eu/apidoc · info.greynoise.io/community/research-program-request · github.com/cisagov/kev-data · github.com/empiricalsec/epss_scores. Leakage figures from analysis/leakage.py; see README threats 41–44.